

C2PA Generator Product Conformance Review

Date: July 16, 2026

Reviewer: Conformance GPSA Reviewer

Subject: Generator Product Security Architecture Review

Input Document: Scruple — Generator Product Security Architecture Document

Standard: C2PA Generator Product Security Requirements v0.1

Executive Summary

Applicant: Docent LLC (dba Scruple)

Product: Scruple C2PA Signer

Class: Distributed

Target Assurance Level: Level 2

Overall Verdict: DOES NOT MEET

Summary:

The product is a cloud-based, distributed C2PA generation service running on Oracle Cloud Infrastructure. The architecture delegates claim generation from a Client to an Application Tier, and finally to an isolated Signer tier. The security design heavily relies on AMD SEV-SNP Confidential VMs acting as a hardware-backed Trusted Execution Environment (TEE), coupled with a PKCS#11 HSM for cryptographic isolation. While the applicant demonstrates an exceptionally strong grasp of key protection, memory encryption, and internal traffic authentication (mTLS 1.3 with per-request seals), the architecture fails to meet the strict Level 2 requirements for continuous, dynamic validation of the OS Security Patch level. Specifically, the system relies on point-in-time build measurements and manual advisory cross-referencing rather than an automated, continuous enforcement mechanism against a 90-day rolling window. The product currently aligns with Level 1 assurance but requires architectural remediation to achieve Level 2.

Detailed Compliance Report

1. Security Objective O.1: Proof of Eligibility

Requirement Reference	Requirement Description	Verdict	Reviewer Notes
Req 6.1.1 (Level 1) / 6.1.2 (Level 2)	Automated certificate enrollment mechanisms must properly authenticate the applicant and securely manage	N/A	The applicant explicitly states that enrollment is manual via a CSR submitted to a Trust List CA portal. The requirement only applies to

	CSRs.		automated enrollment mechanisms (e.g., ACME). The applicant's manual CSR generation inside the TEE is acceptable and appropriate.
--	-------	--	---

2. Security Objective O.2: Signing-key confidentiality

Requirement Reference	Requirement Description	Verdict	Reviewer Notes
Req 6.2.1 (Level 1)	The signing key must be protected against unauthorized extraction or access.	MEETS	Applicant uses an ECDSA P-256 key generated inside a PKCS#11 HSM. The key is configured with attributes preventing extraction/export, exposing only the C_Sign operation.
Req 6.2.2 (Level 2)	Hardware-backed isolation and attestation of key generation and storage.	MEETS	The applicant correctly utilizes an AMD SEV-SNP Confidential VM (a hardware-backed TEE). Crucially, they securely bind the HSM key to the TEE by hashing the public key SPKI into the report_data field of the hardware attestation report.

			The inclusion of live attestation bundles demonstrates that this is implemented, not just planned.
--	--	--	--

3. Security Objective O.3: Claim Generator hardening

Requirement Reference	Requirement Description	Verdict	Reviewer Notes
Req 6.3.1 (Level 1)	Protection against abuse via vulnerability scanning, patching, and secure compilation.	MEETS	Applicant implements SCA, Container scanning, SAST, and SBOM generation in CI. Compiler/linker hardening (ASLR, DEP/NX, PIE, FORTIFY_SOURCE) is enforced on the reproducible Signer image.
Req 6.3.2 (Level 2)	Advanced hardening, hardware/OS attestation, and strict enforcement that all software is patched within 90 days of a Critical/High vulnerability detection.	DOES NOT MEET	Critical Gap: The applicant relies on the SEV-SNP TCB field and boot image measurements to prove what software is running, and uses a CI release-blocker to ensure <i>new</i> deployments are patched. However, they do not describe an explicit, dynamic

			mechanism to extract and validate the OS Security Patch Date of a <i>running</i> instance against a 90-day rolling window. A static boot measurement "verifiable against vendor's published advisories" requires human intervention and does not prevent a running CVM from aging past the 90-day threshold without being replaced.
--	--	--	--

4. Security Objective O.4: Content-processing hardening

Requirement Reference	Requirement Description	Verdict	Reviewer Notes
Req 6.4.1 (Level 1)	Input validation, isolation of content-processing pathways, and sandboxing.	MEETS	The Signer runs under a heavily sandboxed systemd unit (ProtectSystem=strict, NoNewPrivileges=yes, MemoryDenyWriteExecute=yes, etc.). Input validation occurs at the Application tier, followed by JSON schema and

			round-trip manifest validation at the Signer boundary.
Req 6.4.2 (Level 2)	Content-processing software and underlying OS must have security patches applied within 90 days.	DOES NOT MEET	Critical Gap: Same deficiency as 6.3.2. Because the OS (CVM kernel/userland) handles network inputs and mediates the content-processing environment, the OS is part of the Target of Evaluation (TOE). The architecture lacks an automated capability to evaluate the instance's OS patch recency against the 90-day requirement continuously.

5. Security Objective O.5: Traffic protection

Requirement Reference	Requirement Description	Verdict	Reviewer Notes
Req 6.5.1 (Level 1 & 2)	External and internal traffic must be strongly encrypted and mutually authenticated in Distributed classes.	MEETS	The applicant enforces TLS 1.3 for external traffic (with an acceptable 1.2 floor). For internal Distributed-Class routing, the Application Tier and

			Signer communicate via an isolated network using mTLS 1.3 with pinned peer certificates. The addition of a per-request authentication seal with skew tolerance is an excellent defense-in-depth measure.
--	--	--	--

6. Security Objective O.6: Hosting environment

Requirement Reference	Requirement Description	Verdict	Reviewer Notes
Req 6.6.1 (Level 1 & 2)	Secure hosting environment, IAM, logging, network segmentation, and vulnerability disclosure programs.	MEETS	The environment uses instance-bound cloud IAM identities, MFA for human access, and strict network segmentation (Signer has no public IP). System incorporates HIDS (file integrity, socket monitoring) and retains audit logs for 365 days. A compliant Coordinated Vulnerability Disclosure (CVD) SLA is published.

Conclusion & Next Steps

Final Recommendation: NON-CONFORMANT for Level 2 (Conformant for Level 1).

The Scruple C2PA Signer exhibits a sophisticated, well-designed architecture. The integration of AMD SEV-SNP Confidential VMs with PKCS#11 HSMs, strict systemd sandboxing, and mTLS 1.3 IPC demonstrates a robust approach to key secrecy and traffic protection.

However, the architecture fundamentally fails a mandatory Level 2 requirement regarding OS Patch Recency enforcement (Requirements 6.3.2 and 6.4.2). The use of hardware TCB fields and boot measurements provides high integrity but does not natively extract or enforce an OS *Security Patch Date* against a 90-day rolling window for active, running instances. Relying on CI/CD pipelines to block vulnerable *new* releases does not account for long-lived instances whose internal software ages out of compliance over time.

Required Remediation for Level 2:

To achieve a Level 2 conformance rating, the applicant must implement and document an explicit mechanism to continuously or periodically extract the OS security patch status/date of the running CVMs and validate it against a 90-day rolling window. If an instance's OS patch level falls behind this 90-day window, the mechanism must actively alert, terminate the instance, or disable the C_Sign operational capability until the environment is rotated or patched.

Alternatively, the applicant may opt to accept a **Level 1** certification with no architectural changes, as explicitly offered in their Cover Statement.